

---

# Audit de ProspectWeb

## — Version post-remédiation

Contre-audit fondé sur la lecture intégrale du code source et l'exécution réelle du build, des tests et de l'audit de dépendances, en confrontation avec l'audit du 22 juin 2026.

---

OUTIL AUDITÉ

ProspectWeb

DÉPÔT

sofianehms/prospectweb

COMMIT

c94cef9

31/31 ISSUES PW-01 → 31

DATE

24 juin 2026

MÉTHODE

Lecture du dépôt  
+ BUILD, TESTS, NPM AUDIT

DIFFUSION

Restreinte

# Sommaire

|    |                                                |    |
|----|------------------------------------------------|----|
| 1. | Périmètre, méthode et vérifications effectuées | 3  |
| 2. | Résumé exécutif — audit juin vs. audit actuel  | 4  |
| 3. | Audit technique & architecture                 | 6  |
| 4. | Audit de sécurité                              | 8  |
| 5. | Audit produit, UX & expérience client          | 11 |
| 6. | Audit business & stratégique                   | 13 |
| 7. | Conclusion croisée & recommandation globale    | 15 |

Grille de criticité utilisée dans tout le document : **Bloquant** empêche une mise en production ou commercialisation sérieuse — **Majeur** impact fort à corriger avant toute montée en charge — **Mineur** à traiter mais non urgent — **Cosmétique** finition.

Chaque constat distingue le **fait** (vérifié dans le code, référencé `fichier:ligne`, ou par exécution de `tsc/vitest/npm audit`) de l'**opinion** / **recommandation**.

Légende des changements depuis juin : **Corrigé** problème clôturé et vérifié — **Partiel** traité côté code mais résidu ou dépendance externe non vérifiable — **Nouveau** vecteur introduit par la remédiation.

# 1 Périmètre, méthode et vérifications effectuées

Cet audit ne se contente pas de lire les messages de commit ni la déclaration « tout est implémenté ». Le dépôt a été cloné au commit [c94cef9](#), le fichier par fichier (backend Express/TypeScript et frontend Next.js), puis **construit et exécuté** : typecheck, suite de tests et audit de dépendances ont été lancés réellement, pas seulement déclarés.

## Stack technique réellement constatée

| COUCHE           | CONSTAT DANS LE CODE (COMMIT C94CEF9)                                                                                                                                                                                       |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Frontend         | Next.js <a href="#">^15.3.3</a> (App Router), React 19.2.4, Tailwind v4, Leaflet 1.9.4, TypeScript 5. Middleware d'auth global ( <a href="#">middleware.ts</a> ). Déployé sur Vercel.                                       |
| Backend          | Express <a href="#">^5.2.1</a> , TypeScript <a href="#">strict:true</a> , helmet 8, jsonwebtoken 9, bcryptjs 3, ioredis 5, pg 8, express-rate-limit 8. Déployé sur Railway.                                                 |
| Persistence      | PostgreSQL ( <a href="#">services/db.ts</a> : users, prospects, user_usage, google_usage, search_history, plans). Cache Redis ( <a href="#">ioredis</a> ) avec repli mémoire. CRM migré de localStorage vers l'API serveur. |
| APIs tierces     | Google Places (New) searchNearby + Place Details, Google Geocoding (repli Nominatim), Nominatim proxifié côté backend (User-Agent identifiant + throttle), tuiles OSM.                                                      |
| Authentification | Comptes e-mail / mot de passe, JWT (7 j) + secret interne <a href="#">x-internal-secret</a> en défense en profondeur. Quotas par utilisateur et par plan.                                                                   |

## Vérifications exécutées (preuves, pas déclarations)

|                           |                     |                   |                            |                        |
|---------------------------|---------------------|-------------------|----------------------------|------------------------|
| 0                         | 120 / 120           | 17                | 3                          | 0                      |
| ERREUR TSC (BACK + FRONT) | TESTS VITEST PASSÉS | FICHIERS DE TESTS | CVE MODÉRÉES (TRANSITIVES) | ANY / TODO / CODE MORT |

- `npx tsc --noEmit` backend & frontend → aucune erreur de typage.
- `vitest run` (17 fichiers, 120 tests) → tous verts, couvrant récence, cache, SSRF, quotas, auth, rate-limit, sources.
- `npm audit` → backend : 1 modérée ([qs](#), transitive Express) ; frontend : 2 modérées ([postcss/next](#), [build-time](#)). Aucune critique ni élevée.
- `grep` exhaustif → aucun [any](#), aucun [@ts-ignore](#), aucun TODO/FIXME ; [mock.ts](#) et [ThemeProvider.tsx](#) supprimés (vérifié).

## Angles morts assumés

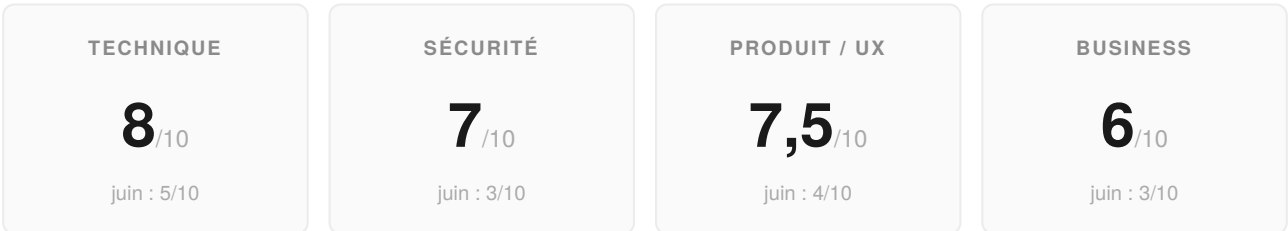
Les éléments suivants ne sont pas vérifiables depuis le code et ne sont donc pas jugés — ils sont signalés comme limites :

- **Console Google Cloud** : quotas QPD par SKU, alertes budgétaires, restriction de clé — hors dépôt, non vérifiables. Le code pose une barrière applicative, mais la barrière plateforme reste un acte de confiance.
- **Infrastructure Railway / Vercel réelle** : nombre d'instances, Redis/Postgres effectivement provisionnés, variables réellement renseignées. Plusieurs garde-fous (quota, rate-limit, circuit-breaker) sont en mémoire et donc **par instance** — voir §4 et §6.

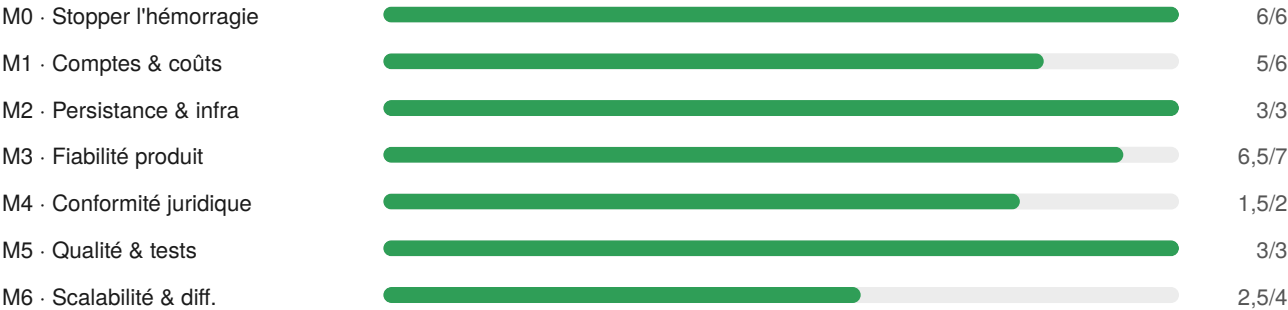
- **Volumétrie, logs et facture Google réels** ; comportement en exécution réelle non testé ; conformité juridique **finale**, qui relève d'un avis juridique et non du code.

## 2 Résumé exécutif

Le verdict de juin — « MVP soigné mais ni déployable sérieusement, ni commercialisable » — n'est plus d'actualité. Les **quatre décisions de conception bloquantes** identifiées en juin (pas d'identité, coût non borné, contenu fabriqué, données tierces non conformes) ont été **substantiellement levées et vérifiées**. ProspectWeb est passé d'un prototype mono-utilisateur à une base SaaS crédible. Il reste une liste courte mais réelle de correctifs avant de facturer des clients.



### Avancement du plan de remédiation (31 issues)



### Les 3 blocants de juin — clôturés

| BLOCANT JUIN                                                                                                   | ÉTAT ACTUEL — VÉRIFIÉ                                                                                                                                                                                                         | STATUT  |
|----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| <b>Robinet de coût Google ouvert</b><br>app anonyme, <a href="#">types</a><br>non filtré → ~250 appels/requête | Auth JWT obligatoire ( <a href="#">requireAuth</a> ) ; liste blanche <a href="#">COMMERCIAL_TYPES</a> + plafond 8 types validés <i>avant</i> tout appel ; quota Google journalier + quota par utilisateur ; FieldMask allégé. | Corrigé |
| <b>Données inventées</b><br>horaires, « Instagram 783 », fiche complète                                        | Aucun résidu (grep + tests <a href="#">pw03</a> ). Champs absents → « Non renseigné ».                                                                                                                                        | Corrigé |

**Exposition juridique**  
ToS Google, RGPD, «  
Pages Jaunes · SIRENE  
»

Mention fausse retirée (tests [pw04](#)) ; purge auto 30 j des données Google, export recentré sur Place ID ; suppression de compte + purge inactifs + page confidentialité. Validation juridique finale toujours requise.

Partiel

## Ce qui bloque encore une commercialisation payante

| # | POINT                                               | CRITICITÉ | POURQUOI                                                                                                                                                                                                                                                                    |
|---|-----------------------------------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | JWT en cookie lisible par JS                        | Majeur    | Le token est posé via <a href="#">document.cookie</a> (login/page.tsx:35), sans <a href="#">httpOnly</a> ni <a href="#">Secure</a> . Couplé à une CSP permissive ( <a href="#">unsafe-inline</a> ), une XSS permet le vol de session. Nouveau vecteur introduit par l'auth. |
| 2 | Pas de facturation réelle                           | Majeur    | Les plans & quotas par plan existent, mais <a href="#">PATCH /api/plans/me</a> laisse l'utilisateur s'attribuer le plan « Business » gratuitement (plans.ts:21). Aucune intégration de paiement.                                                                            |
| 3 | Garde-fous en mémoire par instance                  | Majeur    | Quota Google/utilisateur, store du rate-limiter et circuit-breaker sont en mémoire. En multi-instance, la limite effective $\approx N \times \text{limite}$ : le contrôle de coût se relâche à l'échelle.                                                                   |
| 4 | Différenciateur absent                              | Majeur    | Historique + déduplication + relances livrés, mais l'enrichissement propriétaire (e-mail, dirigeant, SIRET) de PW-30 n'est pas intégré. Le produit reste copiable.                                                                                                          |
| 5 | Endpoint <a href="#">/api/usage</a> non authentifié | Mineur    | <a href="#">index.ts:34</a> expose les identifiants de tous les utilisateurs et leur consommation, sans authentification.                                                                                                                                                   |

Verdict synthétique : **prêt pour un déploiement bêta / facturation pilote après correction des points 1, 2, 3 et 5** (quelques jours d'effort). La levée de fonds ou la vente exigeront en plus le différenciateur (point 4) et un avis juridique. Détail et recommandations actionnables dans les sections suivantes.

## 3 Audit technique & architecture

### 3.1 — Qualité & rigueur

#### Constats

La qualité d'écriture, déjà bonne en juin, s'est consolidée. `strict:true` est tenu : **aucun** `any` ni `@ts-ignore` dans `backend/src` (vérifié par `grep`). `tsc --noEmit` est vert côté backend et frontend. La séparation `routes / services / middleware` reste nette, avec désormais une couche `store` dédiée par entité (`userStore`, `prospectStore`, `planStore`, `searchHistory`). Toutes les requêtes SQL sont paramétrées. Aucun TODO/FIXME ; le code mort de juin a été supprimé.

### 3.2 — Gestion des erreurs & observabilité

L'« avalage silencieux » des erreurs Google de juin est éliminé : `places.ts` journalise `status` et corps puis lève `GoogleApiError` (`places.ts:181-186`) ; `search.ts` distingue 503 (fournisseur) de 502 (interne) et de 429 (quota) (`search.ts:177-184`). Côté client, les messages internes ne fuient plus.

#### RÉSIDU D'OBSERVABILITÉ

L'« alerting exploitant » de PW-29 se limite à `console.error / console.warn` (ex. circuit-breaker, seuil 80 % de quota). Utile en lecture de logs, mais ce n'est pas un canal d'alerte actif (e-mail, webhook). Une panne Google reste donc visible *a posteriori* dans les logs, pas notifiée. **Mineur**

### 3.3 — Tableau de synthèse — Technique

| PROBLÈME                          | ÉTAT JUIN                                         | ÉTAT ACTUEL                                                                                                | CHGT    | CRITICITÉ |
|-----------------------------------|---------------------------------------------------|------------------------------------------------------------------------------------------------------------|---------|-----------|
| Aucun test (PW-25)                | 0 fichier ; CI lint + build                       | 17 fichiers / 120 tests verts ; vitest + tsc en CI ; couvre récence, cache, SSRF, quota, auth              | Corrigé | Majeur    |
| Docs cassent l'install (PW-26)    | <code>.env.example</code> incomplet ; README faux | <code>.env.example</code> complet (clé, secrets, JWT, DB, Redis) ; README aligné ^15.3.3 ; OVERPASS retiré | Corrigé | Majeur    |
| Erreurs Google avalées (PW-05)    | <code>return []</code> sur 403/429                | <code>GoogleApiError</code> propagée et journalisée ; l'UI distingue panne et absence de résultat          | Corrigé | Majeur    |
| Code mort & divergent (PW-27)     | <code>mock.ts</code> , <code>ThemeProvider</code> | Supprimés (vérifié)                                                                                        | Corrigé | Mineur    |
| Messages d'erreur verbeux (PW-06) | <code>err.message</code> au client                | Libellés génériques ; détail conservé en logs serveur (tests <code>pw06</code> )                           | Corrigé | Mineur    |

|                                       |                             |                                                                                              |         |        |
|---------------------------------------|-----------------------------|----------------------------------------------------------------------------------------------|---------|--------|
| Désynchro<br>état multi-<br>instance  | Cache mémoire<br>(existant) | Cache → Redis ; mais quota et circuit-breaker<br>restent en mémoire / par instance           | Partiel | Majeur |
| Attribution<br>d'appels<br>(métering) | —                           | Calculée via delta d'un compteur global<br>(search.ts:120-124) → imprécise en<br>concurrence | Nouveau | Mineur |

## Recommandations — Technique

1. Rendre les compteurs de quota autoritatifs côté Redis/Postgres (incrément atomique) plutôt qu'en mémoire, et faire du circuit-breaker un état partagé.
2. Attribuer les appels par un compteur retourné par [nearbySearch](#) (et non un delta global) pour fiabiliser le métering sous charge.
3. Brancher un vrai canal d'alerte (e-mail/webhook) sur les erreurs Google et le seuil de quota.
4. Traiter les CVE modérées via [npm audit fix](#) (qs, postcss) au prochain bump.



## 4 Audit de sécurité

### 4.1 — Authentification & autorisation

#### Constats

**Point positif** : comptes e-mail/mot de passe (`bcrypt`, coût 10), JWT 7 jours ; `requireAuth` posé sur `/api/search`, `/prospects`, `/establishment`, `/history`, `/plans` ; `middleware.ts` redirige tout le frontend non public vers `/login`. Secret interne conservé en défense en profondeur, désormais comparé en temps constant (`timingSafeEqual`, `auth.ts:16`). Tests `pw07`.

#### NOUVEAU VECTEUR : JWT VOLABLE PAR XSS

Le token est écrit côté navigateur via `document.cookie = pw_token=...; SameSite=Lax` (`login/page.tsx:35`), donc **sans `httpOnly` ni `Secure`** : lisible par n'importe quel script. Or la CSP autorise `script-src 'unsafe-inline' 'unsafe-eval' (next.config.ts)`, ce qui neutralise la protection XSS attendue. Une injection suffit à voler la session. **Majeur**. Correctif : poser le cookie côté serveur (route `/api/auth/login`) en `httpOnly` ; `Secure` ; `SameSite=Lax` et retirer `unsafe-inline/eval` de la CSP.

Énumération de comptes (Mineur) : à `/login`, un e-mail inexistant répond sans calcul `bcrypt` → écart de timing exploitable (`auth.ts:44-48`).

### 4.2 — Rate limiting & amplification de coût

| SUJET                                | ÉTAT JUIN                | ÉTAT ACTUEL                                                                                    | STATUT  |
|--------------------------------------|--------------------------|------------------------------------------------------------------------------------------------|---------|
| Paramètre <code>types</code> (PW-01) | Non filtré → ~250 appels | Liste blanche + plafond 8, validés avant Google ( <code>search.ts:77-92</code> ). Tests dédiés | Corrigé |
| Clé du rate-limiter (PW-09)          | IP de Vercel partagées   | Clé sur <code>req.user.sub</code> ; <code>trust proxy</code> posé                              | Corrigé |
| Store du rate-limiter (PW-09)        | Mémoire                  | Toujours en mémoire : pas de store Redis branché → non partagé, remis à zéro au redéploiement  | Partiel |
| Quota de coût                        | Aucun                    | Quota Google/jour + quota/utilisateur + plafond par plan ; mais en mémoire par instance        | Partiel |

### 4.3 — SSRF, en-têtes, fuites

#### Constats

**SSRF durci (PW-10)**. Avant chaque requête, le hostname est résolu et les IP privées/loopback/link-local sont bloquées (`isPrivateIp`, plages `v4 + ::1/fc00/fe80`) ; redirections en mode `manual`, plafonnées à 3, et l'IP est **revérifiée à chaque saut** (`websiteChecker.ts:115-127`). Timeout 6 s et lecture plafonnée à 50 Ko conservés. Tests `pw10`.

Résidu (Mineur) : fenêtre de DNS-rebinding — `lookup()` valide une IP, puis `fetch()` re-résout indépendamment (TOCTOU).  
Atténuation : épingler l'IP résolue ou passer par un proxy de sortie cloisonné.

| SUJET                            | ÉTAT JUIN                            | ÉTAT ACTUEL                                                                                                                      | STATUT  |
|----------------------------------|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|---------|
| En-têtes (PW-11)                 | Aucun (helmet/CSP absents)           | <code>helmet</code> + CSP/HSTS/X-Frame-Options/Referrer/Permissions (next.config). CSP toutefois <code>unsafe-inline/eval</code> | Partiel |
| Nominatif navigateur (PW-12)     | Appel direct, sans User-Agent        | Proxifié backend, User-Agent identifiant + contact, throttle 1,1 s, cache. Tests <code>pw12</code>                               | Corrigé |
| Géocodage Google verbeux (PW-06) | <code>error_message</code> au client | Détail en logs ; client reçoit un libellé générique                                                                              | Corrigé |
| <code>/api/usage</code> global   | —                                    | Non authentifié : expose les identifiants et la consommation de tous les utilisateurs (index.ts:34)                              | Nouveau |

## 4.4 — Scénarios d'attaque rejoués

### A — ÉPUISEMENT FINANCIER (RÉUSSISSAIT EN JUIN)

Neutralisé. Sans compte, aucune recherche ne part (401). Avec un compte : liste blanche + plafond de types, quota Google/jour et quota/utilisateur arrêtent l'abus. Réserve : en multi-instance, les quotas en mémoire se cumulent ( $\approx N \times$ ). À fiabiliser via Redis/DB.

### B — SONDE SSRF VIA FICHE GOOGLE (RÉUSSISSAIT PARTIELLEMENT)

Bloqué pour les IP privées, y compris après redirection. Reste la fenêtre théorique de DNS-rebinding (Mineur).

### C — VOL DE SESSION VIA XSS (NOUVEAU)

JWT lisible par JS et CSP permissive : une XSS exfiltre le token et usurpe la session. **C'est le risque de sécurité n°1 restant.**

## Recommandations — Sécurité (par priorité)

- Poser le JWT en cookie `httpOnly; Secure; SameSite=Lax` côté serveur et retirer `unsafe-inline/eval` de la CSP (nonces Next). **Majeur**
- Authentifier (ou retirer) `/api/usage` global. **Mineur**
- Externaliser le store du rate-limiter (Redis) et rendre les quotas autoritatifs en base. **Majeur**
- Épingler l'IP résolue lors du `fetch` de vérification de site (anti-rebinding) ; uniformiser le timing du login. **Mineur**

## 5 Audit produit, UX & expérience client

*Posture client final.* Je paie pour des prospects fiables, vite, en confiance. Le point qui cassait cette confiance — les données inventées — a disparu, le signal de qualification est devenu honnête, et les fonctions fantômes sont câblées ou retirées.

### 5.1 — Fiabilité perçue, le cœur de la promesse

#### Constats

**Signal de récence refondu (PW-16).** Fin du « 2025 dans le texte = actif ». Désormais 7 indices pondérés (Last-Modified, dates meta OG/schema, JSON-LD, balise `<time>`, sitemap, framework moderne, année — plafonnée à 10 pts) produisent un score de confiance affiché à l'utilisateur, et 4 états distincts : sans site / injoignable / obsolète / actif. Un site momentanément **injoignable n'est plus classé « obsolète »** (search.ts:27-36). Tests [pw16](#).

Résidu (Mineur) : un site qui répond 403/404 à un robot (anti-scraping) reste « reachable » (status < 500) et finit « obsolète » faute d'indices. La confusion bloqué/obsolète subsiste à la marge.

### 5.2 — Fonctions fantômes : câblées ou retirées

| ÉLÉMENT                             | ÉTAT JUIN                           | ÉTAT ACTUEL                                                                                                      | CHGT    |
|-------------------------------------|-------------------------------------|------------------------------------------------------------------------------------------------------------------|---------|
| Filtres rapides (PW-17)             | 5 filtres décoratifs                | Réduits à 2 réels (Sans site / Obsolète), transmis en URL et appliqués côté résultats                            | Corrigé |
| Bouton « Envoyer un email » (PW-17) | Mort                                | Retiré ; remplacé par « Appeler » ( <a href="#">tel:</a> ) et « Itinéraire » réels                               | Corrigé |
| CRM & notes de la fiche (PW-18)     | <code>useState</code> local, perdus | Persistés via <code>useProspects</code> vers l'API serveur (statut immédiat, notes débouncées)                   | Corrigé |
| Liens profonds (PW-19)              | Cassés hors session                 | Repli <code>sessionStorage</code> → cache backend. OK en session et fenêtre TTL ; au-delà de 10 min, introuvable | Partiel |
| Résultats partiels (PW-21)          | Silencieux                          | Bannière « résultats incomplets » avec types plafonnés ou en échec                                               | Corrigé |
| États de chargement (PW-20)         | Page figée                          | <code>loading.tsx</code> : skeleton + indicateur de progression immédiat ; bannière d'erreur distincte           | Corrigé |
| Libellés & accessibilité (PW-22)    | Chaînes brutes, couleur seule       | Configuration de types partagée, <code>aria-hidden</code> sur icônes, badges texte                               | Corrigé |

UX à surveiller : ouvrir une fiche détail **ajoute automatiquement** le prospect (DetailClient.tsx:48-50). Pratique pour la persistance, mais « consulter = enregistrer » peut surprendre et gonfler « Mes prospects ». À rendre explicite.

### 5.3 — Comparaison marché & manques

Acquis désormais au niveau attendu d'un outil B2B : comptes, CRM serveur multi-appareil, historique de recherche, déduplication (marquage « déjà ajouté »), relances datées, export CSV conforme, script d'appel.

Manque encore, face à un concurrent comme prospectweb.fr : l'**enrichissement** (e-mail, dirigeant, SIRET) — les actions e-mail ont d'ailleurs été retirées faute de donnée — et des intégrations CRM externes.

### Recommandations — Produit / UX

1. Rendre les liens profonds réellement durables : re-résoudre par Place ID au-delà du TTL (résidu PW-19).
2. Distinguer « bloqué par anti-bot » d'« obsolète » dans le classement.
3. Rendre l'ajout au CRM explicite (bouton) plutôt qu'automatique à l'ouverture de fiche.
4. Prioriser une première source d'enrichissement licite — c'est le chaînon produit et stratégique manquant.

## 6 Audit business & stratégique

*Posture patron / investisseur.* Combien ça coûte à l'échelle, qu'est-ce qui me protège, puis-je le vendre légalement ? Les trois réponses se sont nettement améliorées, mais la monétisation et la défensabilité restent les deux trous à combler.

### 6.1 — Modèle de coûts

| LEVIER DE COÛT<br>(JUIN)      | ÉTAT ACTUEL — VÉRIFIÉ                                                                                                                                                                                  | CHGT    |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| FieldMask « cher » (PW-28)    | Recherche allégée : <code>phone/rating/ratingCount</code> retirés du <code>FIELD_MASK_SEARCH</code> ; ces champs ne sont chargés qu'à l'ouverture d'une fiche ( <code>fetchPlaceDetails</code> , lazy) | Corrigé |
| <code>types</code> non borné  | Liste blanche + plafond 8 ; arrêt précoce à 15 « sans site » par type ( <code>NO_WEBSITE_TARGET</code> )                                                                                               | Corrigé |
| Cache mémoire fragile (PW-13) | Redis ( <code>ioredis</code> ) partagé + repli mémoire ; TTL préservé                                                                                                                                  | Corrigé |
| Plafond de dépense (PW-02)    | Quota Google/jour applicatif + alerte 80 % en logs + persistance DB. Quotas GCP console = angle mort                                                                                                   | Partiel |

### 6.2 — Continuité fournisseurs (PW-29)

Repli géocodeur Google → Nominatim (`geocode.ts:48-61`) ; circuit-breaker sur Google Places (3 échecs / 60 s, `places.ts:81-102`) ; erreurs remontées, plus de listes vides muettes. Résidus : pas de fournisseur de repli pour Places lui-même ; circuit-breaker en mémoire par instance ; « alerte exploitant » = logs uniquement. **Partiel**

### 6.3 — Scalabilité

Vrais progrès : Postgres et Redis externalisent l'état autrefois en mémoire, et la vérification de sites est désormais bornée par un pool de concurrence et une file d'attente (PW-15, `MAX_CONCURRENT=5`). Mais trois garde-fous restent en mémoire (quota Google, quota utilisateur, rate-limiter, circuit-breaker) : la mise à l'échelle horizontale les dégrade. Le pool de connexions PostgreSQL (max 10) et l'absence de file de jobs asynchrones restent à dimensionner.

### 6.4 — Conformité juridique

| SUJET                          | ÉTAT JUIN                        | ÉTAT ACTUEL                                                                                                                  | CHGT    |
|--------------------------------|----------------------------------|------------------------------------------------------------------------------------------------------------------------------|---------|
| Stockage/export Google (PW-23) | Stockage durable<br>PII + export | Purge auto 30 j ( <code>purgeStaleGoogleData</code> ) ; export recentré sur Place ID + mention de conformité, sans téléphone | Partiel |
| RGPD (PW-24)                   | Aucune base, aucun opt-out       | Suppression de compte (cascade), purge des inactifs > 12 mois, page / <code>privacy</code>                                   | Partiel |

Sources « Pages Jaunes · Retirées (tests [pw04](#)) ; pied de page « Google Maps · OpenStreetMap »  
fausses SIRENE »  
(PW-04)

Corrigé

Réserve d'auditeur : le code fait désormais le raisonnable, mais (a) exporter nom et adresse reste un arbitrage juridique, et (b) il manque un opt-out pour les personnes prospectées (différent de la suppression du propre compte de l'utilisateur) et la base légale documentée. Ces points relèvent d'un avis juridique, pas du code.

## 6.5 — Défensabilité & viabilité SaaS

| SUJET                   | ÉTAT JUIN                  | ÉTAT ACTUEL                                                                                                                                                 | CHGT    |
|-------------------------|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| Différenciateur (PW-30) | Copiable en quelques jours | Historique, déduplication et relances livrés ; enrichissement (e-mail/SIRET) absent → barrière toujours faible                                              | Partiel |
| Multi-tenant (PW-31)    | Mono-utilisateur           | Isolation par utilisateur et plans/quotas en place ; aucune facturation, et <a href="#">PATCH /plans/me</a> permet de s'attribuer « Business » gratuitement | Partiel |

### Recommandations — Business (par priorité)

1. Brancher une facturation (Stripe) et verrouiller le changement de plan derrière le paiement — sinon les quotas par plan sont décoratifs. Majeur
2. Construire un enrichissement propriétaire / licite : c'est la seule vraie barrière à l'entrée. Majeur
3. Rendre quotas et rate-limit autoritatifs et partagés avant tout autoscaling, pour que le contrôle de coût tienne à l'échelle. Majeur
4. Sécuriser juridiquement : avis sur l'export, base légale RGPD, opt-out tiers, et confirmer les quotas/budgets dans la console GCP.

## 7 Conclusion croisée & recommandation globale

### 7.1 — Les trois postures, confrontées

| POSTURE                       | VERDICT POST-REMÉDIATION                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Patron / investisseur         | « On a une vraie base, pas seulement une idée. Le coût est borné, l'identité existe, la conformité est amorcée. Avant que je finance ou que j'achète, je veux deux choses : une facturation réelle — pas un plan qu'on s'auto-attribue — et un différenciateur qui empêche un concurrent de me cloner en une semaine. La sécurité a un trou — le token volable — qui est rédhibitoire avant d'ouvrir au public. » |
| Client final                  | « Maintenant je fais confiance aux données : plus d'horaires inventés, un site classé "obsolète" l'est avec un score à l'appui, mes notes et mon statut me suivent d'un appareil à l'autre. Il me manque surtout les e-mails des prospects pour vraiment gagner du temps. »                                                                                                                                       |
| Auditeur technique & sécurité | « Code propre, strictement typé, 120 tests qui passent, CI sérieuse, SSRF traité, entêtes posés : c'est un autre projet qu'en juin. Mais je vois un JWT lisible par JS sous une CSP permissive, un <code>/api/usage</code> ouvert, et des garde-fous en mémoire qui se relâchent dès la deuxième instance. Ce ne sont pas des détails : ce sont les derniers verrous. »                                           |

### 7.2 — Convergence

Les trois regards convergent : ProspectWeb a franchi le seuil qui le séparait d'un produit. Les **7 bloquants de juin sont traités**, dont les 3 majeurs (coût, données fabriquées, sources fausses) clôturés et vérifiés. Ce qui reste n'est plus de l'ordre du « défaut de conception » mais d'une liste finie de verrous : un vecteur de vol de session, l'absence de facturation, des garde-fous à rendre autoritatifs, et le différenciateur produit.

### 7.3 — Recommandation globale

#### DÉCISION

**Prêt pour une bêta fermée / facturation pilote** après correction des verrous de sécurité (JWT httpOnly, `/api/usage`) et de coût (quotas autoritatifs) — de l'ordre de quelques jours. **Pas encore prêt** pour une ouverture publique payante ni pour une levée tant que la facturation réelle et un différenciateur ne sont pas en place.

### Séquencement conseillé

| PHASE                    | CONTENU — CE QU'IL RESTE À FAIRE                                                                                                                                                                                            |
|--------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Verrous<br>jours         | JWT en cookie <code>httpOnly</code> ; <code>Secure</code> + CSP durcie ; authentifier ou retirer <code>/api/usage</code> ; rendre quotas et rate-limit autoritatifs (Redis/DB) ; verrouiller <code>PATCH /plans/me</code> . |
| Monétisation<br>semaines | Facturation (Stripe) liée aux plans/quotas ; métrique fiabilisée (compteur retourné, pas delta global) ; liens profonds durables ; opt-out tiers + base légale RGPD documentée ; avis juridique export / Google ToS.        |

---

|                |                                                                                                            |
|----------------|------------------------------------------------------------------------------------------------------------|
| <b>Défense</b> | Enrichissement propriétaire (e-mail / dirigeant / SIRET) ; fournisseur Places de repli et alerting actif ; |
| trimestre      | couverture de tests étendue ; durcissement anti-rebinding.                                                 |

---

Fin du rapport. Les constats reposent sur la lecture effective du code aux références indiquées et sur l'exécution réelle de [tsc](#), [vitest](#) (120 tests) et [npm audit](#) au commit [c94cef9](#). Les jugements de criticité et recommandations relèvent de l'analyse de l'auditeur ; la configuration d'infrastructure, la volumétrie, la tarification Google et la conformité juridique finale restent des angles morts signalés (§1) et n'ont pas été inférés.